

自有资金 · 单人 · 全自动化 · 决策与执行手册

在 AI 编程生态里 找一门一个人能做的生意

一份可复现、可证伪的商业计划书。它的结论不是「这个项目很好」，而是「在什么条件下值得做、在什么条件下应当立刻停手」——两者都用同一套模型算出来，并且允许自己得出「不建议做」。

基准日

2026-07-27

模型规模

100,000 次蒙特卡洛 · 随机种子 20260727

候选筛选

16 个候选 → 硬过滤淘汰 11 → 入围 5 → 选定 C12

硬约束

1 人 · 20 小时/周 · 现金上限 \$4,500

一键复现

python model/run_all.py

代码版本

git f543c8f

决策纪要

一页读完：结论、条件、与最可能的死法

这份 BP 的量化结论是有条件的否：按每小时 \$30 给自己的时间计价，三年期望值为 **-\$8,126**，Kelly 最优下注比例为 **0**——即「一分钱都不该下」。但这个结论几乎完全悬于一个参数：**你这 20 小时/周的真实机会成本**。

-\$8,126 三年期望值（现金 + 时间机会成本）	\$12.3/h 无差异时薪：低于此值则应当做	1.89% 胜率 P(收益 > 1)	13.2 盈亏比（平均盈利 ÷ 平均亏损）
--	--	--	--

结论的完整表述（三句话，缺一不可）

第一，只算现金，这是一笔好赌注。 现金口径下期望值 +\$6,476，胜率 14.0%。最坏情况亏掉 \$4,500 中的一部分，破产不可能。

第二，把时间按 \$30/小时计价，它立刻变成一笔坏赌注。 三年 3,000 小时值 \$90,000，占全额赌注 \$94,500 的 95.2%。**真正的赌注 95% 是时间，不是钱。** 按这个口径，期望值转负，Kelly 说不要下注。

第三，因此真问题不是「这个项目好不好」，而是「我的 1,000 小时/年在别处值多少钱」。 无差异点是 **\$12.3/小时（约 \$12,313/年）**。若这些小时确有更高价值的替代用途，模型说不要做；若它们本就是会消耗掉的闲暇，模型说可以做。**这个判断只能由你本人作出。**

最可能的死法（按概率排序，全部来自模拟而非猜测）

死法	概率	此时已投入	为什么
止于 Gate 1：没人肯预付	51.0%	96 小时	从「免费愿意用」到「掏钱」是本领域最大的一道坎
止于 Gate 0-B：连免费流量都拿不到	27.3%	70 小时	新页面 12 个月内进 Google 前十的概率仅 6.11%；HN 是脉冲不是渠道
活到第 36 个月但没到盈亏平衡	16.4%	约 2,900 小时	这是最贵的死法：走完全程，实现时薪低于 \$12.3
运营期被平台方打包进免费订阅	4.6%	视时点而定	GitHub / Cursor 的历史行为模式

概率之和不为 1：表中「活到第 36 个月但未达盈亏平衡」与其余各项在口径上有重叠，此处按「最可能的死法」分类呈现，精确的互斥分布见第 8 章。

这份文件最反常的一点

它把**最不利**的数字放在**第一页**，而不是藏进附录。原因是它的读者只有一个人，而这个人半年后会需要的不是鼓励，是刹车。一份让人读完热血沸腾的 BP，对单人创业者是负资产。

目录

本文件的组织方式

章节顺序不是按「讲故事」排的，而是按**依赖关系**排的：后一章的前提必须在前一章被验证过。第 1-3 章界定什么是真的，第 4-5 章据此选赛道与定产品，第 6-7 章算它能不能挣钱，第 8-9 章算风险与止损，第 10-12 章处理执行、合规与自我证伪。

01 **结论与它的适用条件** 为什么同一组数据能同时支持「做」与「不做」

02 **已核实的事实基础** 一手来源、日期、证据分级

03 **已证伪的叙事** 行业里流传甚广但经不起查的六条，列为明令禁用

04 **赛道重选** 16 个候选 · 12 条硬过滤 · 9 维加权 · 敏感性与稳健性

05 **产品定义** C12: agent CI 配置安全审计

06 **获客方案** 本项目的主要矛盾，写得比产品方案更详细

07 **单位经济学与漏斗** 含一个把所需流量砍掉 63% 的开关

08 **风险量化** 蒙特卡洛 · 胜率盈亏比 · Kelly · 四种年化口径

09 **阶段目标与止损门** 客观标准、未过时的动作、现金与工时双轨止损

10 **无人化运营架构** 零员工、零人工客服如何真正成立

11 **合法合规与能力边界** 明确写出「这些问题我不给答案」

12 **红队自检与逆否检验** 主动写出「什么证据会证明我错了」

附录 A · 方法论：被禁用的公式与不适用的指标

附录 B · 假设总表与出处

附录 C · 复现说明与文件清单

第一章

结论与它的适用条件

同一组模拟数据，换一个记账口径，会得出方向相反的结论。这不是模型不稳，而是「值不值得做」本来就**不是一个纯客观问题**——它取决于一个只有你自己知道的数：你的时间值多少钱。本章把这件事讲透，之后所有章节都在这个框架下展开。

1.1 两个口径，两个相反的答案

两种记账口径下的同一个项目

	现金口径	全口径（现金 + 时间）
赌注	\$4,500	\$94,500
三年期望值	+\$6,476	-\$8,126
胜率 $P(\text{收益} > 1)$	14.01%	1.89%
盈亏比	230.2	13.2
Kelly 最优比例 f^*	1.155	0
Kelly 的建议	满仓，甚至该加杠杆	一分钱都不要下

两列来自完全相同的 100,000 次模拟，唯一差别是时间的计价方式。

现金口径的自我否定

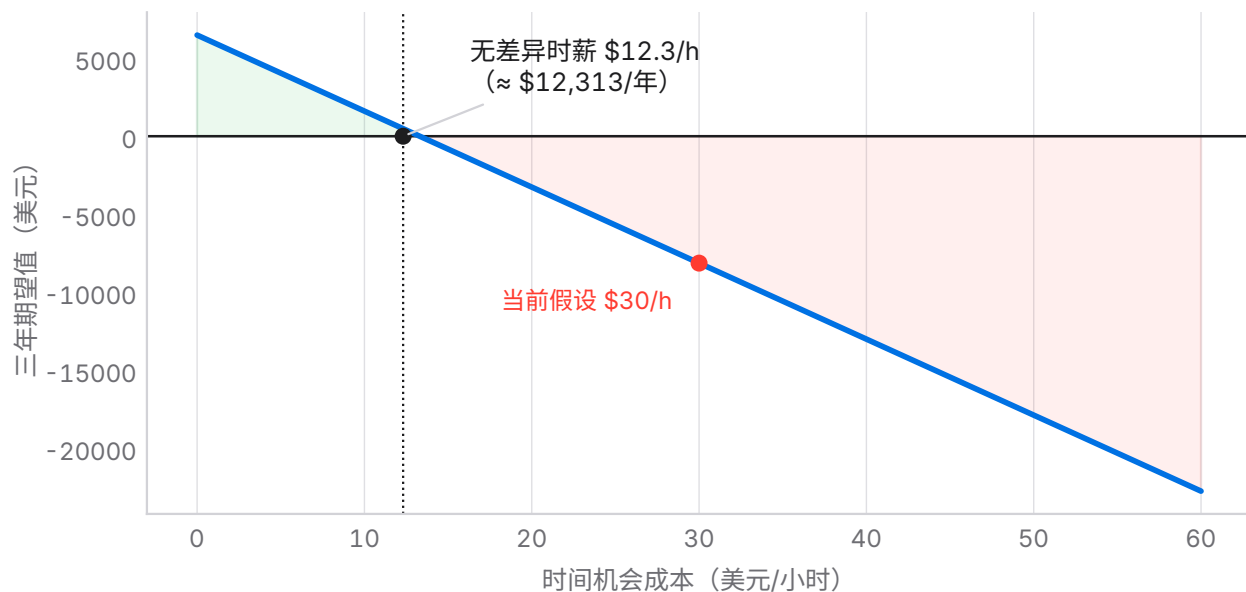
注意现金口径那一列的 Kelly 值： $f^* = 1.155 > 1$ ，意思是「押上全部身家的 116% 还不够」。这是个荒谬的处方，而荒谬恰恰有用：**它证明现金口径本身是错的。**

Kelly 之所以敢让你满仓，是因为在该口径下你几乎亏不掉什么（最差路径仍回收 13.4%）——而这只是因为它把三年 3,000 小时当成了免费的。一个模型给出「无限加杠杆」的建议时，要怀疑的是模型，不是自己的胆量。

1.2 唯一真正需要你回答的问题

把时间机会成本从 \$0 连续调到 \$60/小时，期望值会从 +\$6,476 单调降到 -\$22,728，中间穿过零点。这个零点就是决策的分水岭。

整份分析里最可操作的一张图：时薪多少以下才值得做



无差异时薪 **\$12.3/小时**。换算成年：这 1,000 小时/年若能在别处挣到超过 \$12,313，就不该做这个项目；挣不到，就该做。曲线单调递减，因为时薪只出现在成本侧。数据源 `outputs/results.json` → `ev_sweep`。

请诚实回答这三个问题，再决定要不要往下读

1. 这 20 小时/周是从哪里挤出来的？如果是从另一份能付你 \$20/小时以上的工作里挤的，模型的答案是不做。
2. 如果三年后一分钱没挣到，这段时间算白费吗？如果你认为学到的东西本身有价值，那么真实的机会成本低于账面。
3. 你能接受 92.8% 的概率连 \$1,000 MRR 都达不到吗？这不是悲观设定，是模型输出（见第 8 章）。

1.3 本 BP 保留「不建议做」的权利

这份文件从一开始就允许自己得出否定结论，并且事实上得出了一个有条件的否定结论。这不是消极，而是遵守「实事求是」的必然结果。如果量化筛选后所有候选的风险调整期望值都为负，它就会这么写，并给出替代的资金与时间配置建议——而不是把数字调到好看为止。

第二章

已核实的事实基础

以下每一条都有一手来源与核实日期。它们共同划定了边界：哪些路走不通（2.1），还剩下什么（2.2）。本章的作用是把后面所有推理钉在可查证的地面上。

2.1 否决性事实：把三条最直觉的路先堵死

A 在 Cursor 插件市场收费是合同层面的明文禁止

Marketplace Publisher Terms 第 3.1 条要求插件必须免费提供，发布者「不得以任何直接或间接方式向用户收取费用」；且所有插件必须开源、人工逐个审核、目前为策展制而非开放注册。任何以「上架 Cursor 插件市场变现」为前提的模型，前提不成立。来源：cursor.com/marketplace-publisher-terms（2026-07-27 核）

A 代码审计赛道平台方已自营两个产品

Bugbot 于 2025-07-24 GA，2026-05 改为纯用量计费（官方口径 \$1.00–1.50/次），2026-06 由自研 Composer 2.5 驱动后提速 3 倍、降本 22%，且已同时支持 GitHub 与 GitLab。Cursor Security Review 于 2026-04-30 进入 beta。来源：cursor.com/docs/bugbot.md、[changelog/04-30-26](https://cursor.com/changelog/04-30-26) (<https://cursor.com/changelog/04-30-26>)

A 第三方在推理成本上有约 6 倍的结构性劣势

Composer 2.5 为 \$0.5/M 输入、\$2.5/M 输出；第三方调用 Claude 级模型约 \$3/M 输入，Teams/Enterprise 还要再叠加 \$0.25/M 的 Cursor Token Rate。这个差距无法靠工程优化弥补，因此凡与平台方自营产品正面重叠者一律出局。来源：[models-and-pricing](https://cursor.com/docs/models-and-pricing.md) (<https://cursor.com/docs/models-and-pricing.md>)

A 团队效能分析已被官方以第三方无法复制的方式占据

AI 代码归因靠设备端对每行 AI 建议签名再与 git commit 比对，只有编辑器本身能产生该数据。第三方只能靠启发式 diff，精度天然落后。来源：[ai-code-tracking-api](https://cursor.com/docs/account/teams/ai-code-tracking-api) (<https://cursor.com/docs/account/teams/ai-code-tracking-api>)

A 所有权变更风险已实际发生

SpaceX 于 2026-06-16 签署收购 Anysphere 的合并协议，隐含股权价值 600 亿美元，全股票，预计 2026 Q3 交割。Publisher Terms 是可单方修订的合同，新所有者无义务延续现有生态政策。来源：[SEC 8-K 原文](https://www.sec.gov/Archives/edgar/data/1181412/000162828026043411/spaceexplorationtechnologi.htm) (<https://www.sec.gov/Archives/edgar/data/1181412/000162828026043411/spaceexplorationtechnologi.htm>)

由此得出的第一条设计原则

不要把生意建在任何单一厂商的条款之上。跨厂商标准（MCP、AGENTS.md）被 Codex、Copilot、Gemini CLI、Aider、Windsurf、Zed 原生读取，分发不由任何一家的条款决定。这一条后来成了打分表中权重第二高的维度。

2.2 建设性事实：还剩下什么

A 需求侧出现了「验证类」产品有利的背离

采用率上升而信任度下降：84% 的开发者使用或计划使用 AI 工具（2024 年为 76%），但信任 AI 输出准确性的仅 29%，较 2024 年的 40% 连续第二年下滑，46% 明确不信任。来源：[Stack Overflow Developer Survey 2025](https://survey.stackoverflow.co/2025/ai/) (<https://survey.stackoverflow.co/2025/ai/>)，49,000+ 样本 / 177 国

A 无人化收款通道成立，且是本轮最有价值的发现

Stripe 明确不支持中国大陆主体；Polar 与 Lemon Squeezy 的收款国清单含港澳台而不含中国大陆；唯 Paddle 在国别与币种两层均支持——其不支持国清单（26 项）不含中国，且 CNY 是官方支持的打款币种。这把一个可能坍塌整个模型的二元风险，变成了一个已知的成本项。详见 [docs/GATE0.md](#)。

A 平台方主动让出的一个位置

官方 MCP Registry 文档白纸黑字声明自己不做安全扫描、留给「下游聚合方」。这是本次扫描中唯一一例平台方明示放弃的领域。

2.3 被低估的头号风险：免费开源工具过剩

这是赛道扫描的核心发现，重要到必须单独立为一条硬过滤器。几乎每个候选方向上都已存在 4-12 个免费开源实现：slopsquatting 检测至少 9 个、MCP 安全扫描 4 个以上（含 NVIDIA 官方开源的 SkillSpector）、AI 代码溯源 5 个功能高度重叠、死代码检测被 Knip 占据（11,752 stars、Vercel 用它删掉约 30 万行、且已自带 MCP）。

这不是空白市场，是「做的人太多、但都不收钱」的市场

开发者是最不愿为「一个能用 npx 跑的脚本」付钱的人群。据此设立硬过滤器第 8 条：凡核心功能可被一个免费 CLI 完整替代者，一律淘汰；能收费的必须是 CLI 在结构上做不到的持续托管态（持续监控、状态留存、跨时间比对）。这一条后来淘汰了 11 个候选中的 6 个。

2.4 一次必须记录在案的自我修正

本项目最初的定位是「面向 Cursor Teams 客户做本地 AI 代码归因 + ISO 27001 证据包」。经扫描复核后已被推翻：该品类上游是 DX、LinearB、Jellyfish、Swarmia、Waydev 五家已建制平台（DX 已做到行级归因并按 AI 占比分档对比 revert rate）；且我未能找到工程负责人抱怨「看不到这些数据」的任何一手帖子，需求证据为零。

原始机会卡片中的「机会价值分 50.2 / 综合评分 6.37 / 搜索量 50,000」来自本地启发式评分，无外部可查证依据，不得作为任何决策输入。此处如实保留判断被推翻的痕迹，不是为了显得谦虚，而是因为下一章要用同样的标准去否定别人的说法，那就必须先用它否定自己的。

第三章

已证伪的叙事：本文件明令禁用

以下六条在行业里流传甚广，写进 BP 会被内行读者当场戳穿。逐条列出并禁用，是为了防止自己在后面某一章里图省事又把它们捡回来。

3.1 三条监管叙事

—「EU AI Act 要求审计 AI 生成的代码」—

纯属营销话术。AI Act 监管的是 AI 系统作为产品本身（招聘、信贷、医疗器械等高风险用途），**完全不监管用 AI 编写普通商业软件**。且 Digital Omnibus 已于 2026-07-27 生效，将高风险义务从 8 月 2 日推迟至 2027-12-02。

—「美国 SSDF / EO 14028 构成强制要求」—

联邦强制力在 EO 14306（2025-06）与 OMB M-26-05（2026-02）之后**已实质瓦解**。

「EU CRA 是恐惧驱动的大生意」——半真

CRA（EU 2024/2847）确实是唯一真实的硬时间窗口：第 14 条漏洞报告义务自 2026-09-11 适用，2027-12-11 全面适用。**但恐惧比营销宣称的弱得多**：CRA Art. 64(10) 对开源管理者**完全免除行政处罚**，微型/小型制造商对部分时限亦有豁免。且该位置属于需要漏洞情报数据库的重资产厂商（Snyk / Socket / Aikido / Sonar），单人无法自建。

3.2 两条市场叙事

—「AI 代码度量是新品类空隙」—

它是 2026 年的入场券，**不是空隙**。LinearB、Swarmia、DX、Waydev、Faros 五家全部已上线；Waydev 更把 AI 成本度量（Tokenmeter）做成**免费**获客层。Faros 甚至公开发文称「代码有多少是 AI 生成的」本身就是个错误的问题。

—「赛道竞争激烈但还在增长」—

已进入整合期。Sonar 收购 Gitar；Snyk 的 ARR 达 \$326M 但同比仅增 7%（前一年 27%），估值被 BlackRock 从 \$7.4B 下调至 \$3.7B，2026-02 换 CEO；Haystack 官网 footer 仍停留在 "Copyright © 2023" 且残留占位文字，实质已死。**整合期意味着新进入者的窗口在收窄，而非扩大**。

3.3 一条被我自己算错、又被自己纠正的成本叙事

一个 10 倍的数据冲突，以及它为什么重要

初稿曾写：「Ellipsis 公布一次中等 PR 审查成本 \$0.74，据此反推 Sourcery \$12/席位的毛利率仅约 38%，远低于 SaaS 的 75% 健康线；任何低价席位制 + 每次操作跑 LLM 的模型在结构上就没有毛利空间。」这条差点被写成硬过滤器第 6 条。

它错了。追查 Ellipsis 工程博客原文后确认：\$0.74 是对客报价（token 透传 + 100% 平台费），而其生产环境实际平均成本经优化后为 \$0.12/次（分层模型、增量处理、缓存）。据此重算，竞品毛利率是 80% 而非 38%。

修正动作：硬过滤器第 6 条的适用范围**收窄**为「无成本优化能力者」，而不是笼统地否定所有用量型 LLM 产品。此处保留错误与订正的全过程，因为一个只展示正确结论的文件，读者无从判断其余结论的可靠性。

3.4 被隔离的 C 级数据（不得作为建模输入）

还有一类更隐蔽的污染必须单独隔离：**获客渠道与独立开发者成功率**这两节的市面流通数字，大量来自互相引用的 AI 生成内容农场，层层放大后看似多方印证，追溯下去几乎全部指向同一个未公开方法、未公开数据集的来源。

这类数据已被降级为 **C** 级并单独隔离。**BP 中若在别处再遇到相同数字，不得视为独立印证。**另有四处确实查不到公开数据的项目（开发者工具年留存、Marketplace 安装→付费转化、「12 个月内仍有收入的比例」、单次 PR 审查 token 消耗），一律按类比推算处理并写明类比对象与推算路径。

3.5 三个时效性陷阱（写入模型注释）

项	陷阱	处置
Claude Sonnet 5	2026-09-01 涨价 50% (\$2/\$10 → \$3/\$15)	任何跨越 9 月的测算不得使用现价
DeepSeek v4-pro	现价为促进价，标准价为 4 倍	按标准价建模
DeepSeek 模型别名	deepseek-chat 与 deepseek-reasoner 已于 2026-07-24 停用	不得在代码中引用

第四章

赛道重选：16 个候选，怎么只剩 1 个

本章不接受「我觉得这个方向不错」。16 个候选先过 12 条硬过滤（任一不满足即出局），幸存者再按 9 个维度加权评分，每一维的打分必须附书面理由与至少一个来源，**不允许裸给分**。全部逻辑在 `model/opportunity_scoring.py`，可复算。

16 候选机会	11 硬过滤淘汰	5 进入加权评分	6.97 第一名 C12 得分
------------	-------------	-------------	--------------------

4.1 十二条硬过滤

淘汰条件

- F1 变现路径依赖 Cursor Marketplace 或任何合同禁止收费的渠道（Publisher Terms 3.1 条：插件必须免费提供）
- F2 核心功能与平台方自营产品正面重叠，且该功能已被打包进客户已付费的订阅中（客户获得它的边际价格为零）
- F3 依赖只有编辑器厂商才能采集的数据（如设备端 AI 代码逐行签名）
- F4 需人工销售，或需先有 SOC 2 才能开出第一单
- F5 推理成本不可透传（无法 BYOK，也无法按用量转嫁）
- F6 采用「每次操作跑 LLM」的结构，且不具备分层路由/增量处理/缓存三件套的架构能力（已按 sources.md §4.1 更正：成本是架构问题，不是结构性宿命）
- F7 变现叙事依赖 EU AI Act 或美国 SSDF 对普通软件开发的强制力（该前提不成立）
- F8 核心功能可被一个免费 CLI 完整替代；可收费的必须是 CLI 结构上做不到的持续托管态
- F9 需要重资产才能建立护城河（千万级片段语料库、纵向代码语料、漏洞情报数据库等），\$4,000 预算无法支撑
- F10 产品需对客户作出「你已合规」的法律判定——超出自身能力边界，只可做证据收集
- F11 单人 20 小时每周下 MVP 超过 12 周
- F12 合法性或公序良俗存疑

前三条直接由第 2 章的核实结果转化而来；第 8 条来自 2.3 节的「免费开源过剩」发现；第 6 条经 3.3 节订正后已收窄适用范围。

4.2 十一个被淘汰的候选

ID	候选	触发	一句话理由
C11	slopsquatting 检测（独立产品）	F8	至少 9 个免费 OSS 实现；Augment 已在生成端解决；零付费意愿证据。...
C06	agent / prompt 回归评测	F8	Promptfoo 是免费 OSS CLI 且功能完整；Braintrust、Langfuse 已占满托管形态。...
C10	AGENTS.md / rules 漂移检测	F8	一个脚本即可完成；且论坛证据显示主因是「模型不遵守规则」而非「文件不同步」，解决的是次要矛盾。...
C01	通用 AI 代码审查	F2	Cursor Bugbot 已含在 Cursor Individual/Teams 订阅中；GitHub Copil...
C05	死代码检测	F8	Knip 是免费事实标准：11,752 stars、260 贡献者、ISC 许可、且已自带 @knip/mcp；Ve...
C03	许可证污染 snippet 匹配	F9	护城河是千万级代码片段语料库与索引，\$4,000 预算连一次全量索引都不够。...
C04	AI 技术债度量	F9	结论需建立在纵向大规模代码语料上（GitClear 用了 6.23 亿行变更），单人无法自建；且唯一权威数据的提供者...
C08	EU AI Act Art.50 透明度扫描	F7	范畴错误：Art.50 管的是「你的产品是不是 AI、有没有告知用户」，与「你用 AI 写代码」无关；且 Digit...
C07	私有知识库转 MCP	F8	已有多个免费 OSS 实现；KBKit 等已把该功能降级为免费赠品。...
C09	AI 代码溯源 attestation	F8	agentdiff、aiir、ai-footprint、pedigree、agentmark 等 5 个功能高度重叠...
C02	团队 AI 编码 ROI 报表 / 本地 AI 代码归因	F3、F4	AI 代码归因依赖设备端对每行 AI 建议签名再与 git commit 比对，只有编辑器本身能产生该数据；第三方只...

F2=与平台方自营正面重叠且成本劣势；F3=依赖只有编辑器厂商能采集的数据；F4=需人工销售；F7=变现叙事依赖已被证伪的监管强制力；F8=可被免费 CLI 完整替代；F9=需重资产护城河。

4.3 入围五强与最终排序

通过 12 条硬过滤后的加权评分（前五名）



C12 以 6.97 分居首，领先第二名 C13（6.17）0.80 分。九个维度中权重最高的三项是付费意愿证据强度、单厂商依赖度与无人化获客可行性。

排名	候选	加权得分
1	C12 AI agent 在 CI/CD 中的配置安全审计	6.97
2	C13 MCP server / Agent Skill 的持续供应链监控	6.17
3	C15 EU CRA 证据收集与打包	5.50
4	C14 CI 中 agent 的花费熔断器	5.41
5	C16 AI PR 的审阅证据包	4.63

4.4 两种稳健性检验（比排名本身更重要）

权重敏感性

做了两件事：单维度 $\pm 50\%$ 扰动（回答「哪一维在主导排名」），以及 Dirichlet 随机权重抽样 10,000 次（回答「排名有多稳」）。

结果：单维扰动共 0 次翻转排名；随机权重下 C12 在 99.71% 的抽样中仍居首。结论对权重是稳健的。

分数稳健性（这一项更严厉，也更该看）

动机是一个自我批评：领先候选的高分主要来自「我最容易评估」的维度（可交付性、边际成本结构），而真正决定成败的付费意愿证据分最低（3 分，全表最低）。于是设计三项对抗性检验：

检验	第一名新得分	第二名	是否仍居首
领先者付费意愿分归零	6.43	6.17	是

检验	第一名新得分	第二名	是否仍居首
领先者所有自评维度下调 3 分	6.25	6.17	是
领先者全维 -2 且次名全维 +2（最不利对照）	4.97	7.99	否

第三项是刻意构造的最不利对照（第一名每维 -2、第二名每维 +2）。它会翻转，这在意料之中——列出它是为了标明结论的边界在哪里，而不是为了让结论好看。

必须如实披露的一点

C12 的付费意愿证据是全表最弱的一项：仅有 StepSecurity 的间接类比，没有任何直接证据。即便把这一项归零它仍然领先（6.43 vs 6.17），但这只说明「它在其他维度上足够好」，不说明有人会付钱。

处置：这成了第 9 章 Gate 1 的全部理由，也是本项目最值钱的一道门（价值 \$13,796，见第 9 章）。

第五章

产品定义：C12 · AI agent 在 CI/CD 中的配置安全审计

检测「不受信输入流入 agent 提示 × agent 持有高权限凭据 × 存在外发通道」的致命三角，纯 YAML/AST 规则分析，零推理成本，持续监控仓库配置漂移。

5.1 它检测什么：致命三角

当以下三个条件在同一个 CI 工作流中同时成立时，该仓库就处于可被实际利用的危险中：

1. 不受信输入流入 agent 提示——issue 正文、PR 标题、外部评论被直接拼进提示词
2. agent 持有高权限凭据——GITHUB_TOKEN 写权限、云凭据、包发布令牌
3. 存在外发通道——agent 可执行任意命令、可发起网络请求、可写入仓库

证据来自微软威胁情报、CSA 研究简报、Aikido PromptPwnd、Noma GitLost 四个独立权威源，且均为已确认漏洞而非推测。

5.2 为什么它能通过全部 12 条硬过滤

维度	情况
推理成本	零。纯 YAML / AST 规则分析，不调用任何 LLM——这直接绕开了整个赛道的毛利难题
竞品	通用工具（zizmor、actionlint）不理解 claude-code-action 一类的配置语义；未发现做 agent 语义感知的商业竞品
平台方自营动机	GitHub 自身即 GitLost 的漏洞方，自营动机被其尴尬处境削弱
单厂商依赖	低。跨 GitHub Actions / GitLab CI，且规则本身与厂商无关
20 小时/周可交付性	9/10。纯规则引擎，工程风险是全流程最低的一环
为什么不能只做 CLI	一次性扫描会被免费 CLI 完整替代（触发 F8）。可收费的只有持续托管态：配置漂移监控、跨时间比对、新规则自动回扫

产品形态的唯一正确解

这是本章最关键的一条设计约束，也是 2.3 节那条硬过滤器的直接后果：

免费开放：一次性扫描的 CLI 与 GitHub Action，完全免费、开源。它不是「引流噱头」——它本身就是产品的分发渠道（见第 6 章），也是真正帮到人的部分。

付费：持续监控。「你的 47 个工作流里，昨晚有 3 个的权限配置变了」、「新披露的一类绕过手法，回扫你全部历史配置」。这需要托管状态与时间序列，CLI 在结构上做不到。

5.3 明确不做的三件事

- **不做合规判定。**只输出证据与事实，绝不对客户说「你已合规」——那超出能力边界（硬过滤器第 10 条）。
- **不做通用 SAST / SCA。**那需要漏洞情报数据库，\$4,000 预算撑不起（第 9 条）。
- **不做自动修复的 PR。**在安全场景下自动改别人的 CI 配置，风险与收益不成比例。给补丁，让人自己看过再合。

获客：本项目的核心矛盾

这一章比产品章更长、更详细，因为本项目的核心矛盾不是「做什么产品」，而是「一个每周 20 小时、无广告预算的人如何持续获得精准开发者流量」。把这件事想清楚之前写下的任何一行代码，都可能是浪费。

6.1 为什么获客是核心矛盾

把保守基准串联起来（计算见 `model/funnel.py`）：

每 1,000 个精准访客 × 4.5% 访客→注册	45 个注册
× 3.0% 注册→付费（问卷值 8.9% × 单人折扣）	1.35 个付费客户
× \$19 客单价	\$25.65 新增 MRR
在 7.0% 月流失下，维持 \$1,000 MRR 需要	2,729 个访客/月

\$1,000 MRR 不是一个目标，是一台机器

它需要每月持续喂进 2,729 个精准开发者访客才能不掉。而流量侧的现实是：Ahrefs 追踪 100 万个随机 URL 显示，新页面 12 个月内进入 Google 前十的概率仅 1.74%（高搜索量词 0.3%）；Hacker News 与 Product Hunt 都是 48 小时内衰减到零的一次性脉冲。

一次成功的 HN 头版（保守取 15,000 UV）约产出 56 个付费客户，在 7.0% 月流失下 14 个月后流失殆尽。脉冲不是渠道。

6.2 那个把难度砍掉三分之二的开关

ChartMogul 对 200 个 B2B 软件产品的数据显示一个反直觉的事实：要求信用卡才能开始试用的漏斗，每 1,000 访客产出 10.99 个付费客户；不要卡片的仅 4.005 个。注册量掉 22%，但注册→付费转化率高 3.5 倍。

信用卡开关的敏感性（「单人折扣」= 对 ChartMogul 自报告样本的保守下调）

漏斗设计	访客→注册	注册→付费	每千访客付费数	维持 \$1,000 MRR 所需月访客
不要信用卡（含单人折扣）	4.5%	3.0%	1.35	2,729
不要信用卡（ChartMogul 原值）	4.5%	8.9%	4.00	920
要信用卡（含单人折扣）	3.5%	10.6%	3.70	995

漏斗设计	访客→注册	注册→付费	每千访客付费数	维持 \$1,000 MRR 所需月访客
要信用卡（ChartMogul 原值）	3.5%	31.4%	10.99	335

本 BP 采用第三行（要卡 + 单人折扣）作为基准口径：既取用了这个真实存在的杠杆，又不假设自己能达到问卷样本的平均水平。

这一个产品决策，把维持 \$1,000 MRR 所需的月访客从 2,729 降到 995，降幅 63.5%。在一个「流量是唯一瓶颈」的项目里，这是杠杆率最高的单一决策。

6.3 四条复利渠道 + 一条脉冲渠道

判断标准只有一个：这条渠道是否越用越省力。不满足的一律归为脉冲，不计入稳态基线。

各渠道的月独立访客贡献（UV/月）

渠道	类型	第 12 月	第 24 月	第 36 月	证据
免费 GitHub Action 本体（产品即渠道）	复利	180	600	1,100	D
程序化 SEO 知识库（180 页配置安全条目）	复利	0	440	700	A
负责任披露飞轮	复利	120	300	450	D
被收录进 awesome-list / 他人 README / 安全清单	复利	60	160	250	D
Hacker News / 垂直社群脉冲	脉冲	0	0	0	B

多数为 D 级（本人假设）。这是本 BP 证据强度最弱的一章，也正因如此，Gate 0-B 把「14 天内拿到 300 UV」设成了一票否决项——与其在纸上争论假设是否成立，不如两周内用真实数据证伪它。

为什么这四条是复利的

免费 GitHub Action 本体——产品即渠道

每个安装它的仓库都会在 `.github/workflows/*.yml` 里留下一行公开可见、可被 GitHub 代码搜索索引的引用，也会被该仓库的贡献者读到。安装量本身就是曝光量。

程序化 SEO 知识库（180 页）

每个（agent action × 危险模式）组合一页，内容是具体错误配置示例 + 为什么危险 + 可直接复制的修复补丁。搜索这些具体报错的人，正是处于危险三角中的人。按 Ahrefs 的 6.11% 进前十概率，180 页约有 11 页能进前十。第一年按 0 计（SEO 起量周期 9-18 个月）。

负责任披露飞轮

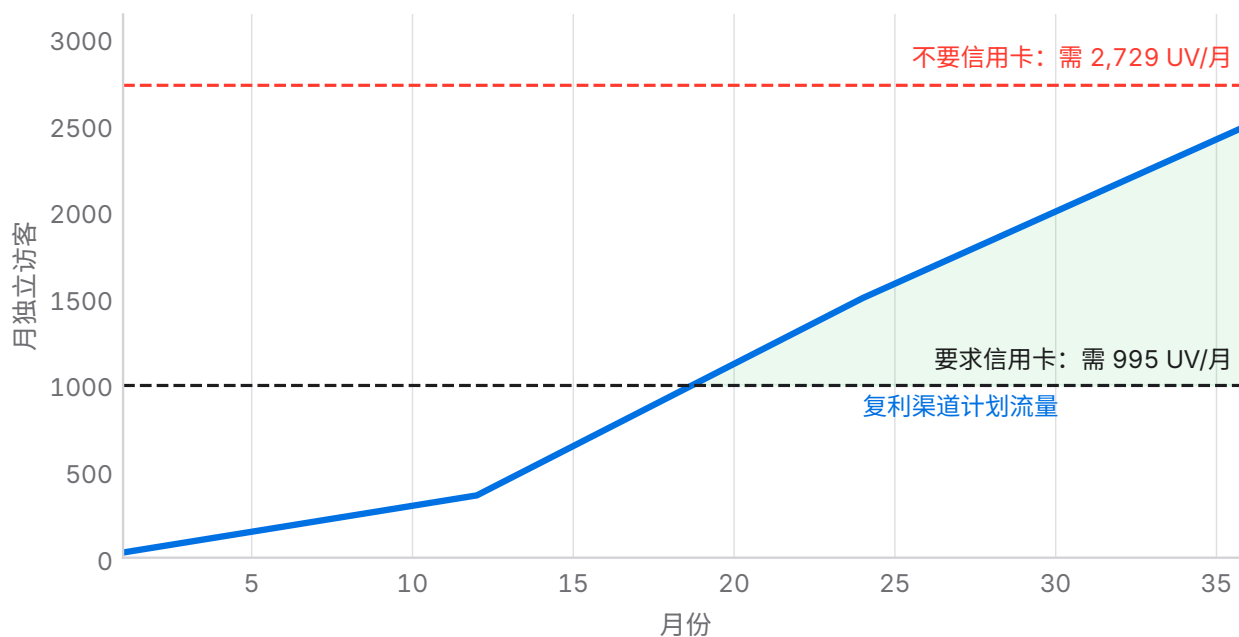
持续在公开仓库中发现真实漏洞，私下告知维护者并附修复补丁。每次披露产生三样东西：一个被修好的仓库、一个知道你是谁为维护者、可能的公开致谢。这是本方案中唯一同时满足「真实帮到人」与「获客」的动作——也是它在道德上最站得住的地方：即使生意失败，被修好的仓库仍然是净收益。

被收录进 awesome-list / 他人 README

安全工具进入 awesome-actions 一类清单后获得长期被动引用。取值刻意保守。

6.4 缺口分析：够，还是不够

维持 \$1,000 MRR 所需流量 vs 计划能拿到的流量



「是否要求信用卡」这一个开关，把所需流量从 2,729 降到 995 UV/月

计划的复利渠道在第 36 月合计 2,500 UV/月。对不要信用卡的漏斗，这是所需量的 91.6%（不够）；对要求信用卡的漏斗，是 251.4%（够，且有 2.5 倍余量）。两条线之间的差距，就是 6.2 节那个开关的价值。

这一章的诚实交代

Gate 0-B 至今没有通过，它只是被形式化成了一个可执行的检验。本章给出的是一个待检验的假设集，不是已验证的结论。任何「我们将通过内容营销获得稳定流量」的表述，在 Gate 0-B 的 B3 项通过之前都属于一厢情愿。

这也是为什么第 9 章把「B3 未过前累计开发工时上限为 0 小时」写成硬纪律：**如果连免费工具都拿不到 300 个访客，那么整份 BP 后面的所有数字都失去了定义域。**

第七章

单位经济学：一个客户到底值多少

本章的结论可以一句话概括：单客户经济性健康，但「盈亏平衡」这个词有两种算法，相差 44 倍。

7.1 单客户月度损益

项	金额
毛收入（\$19/月）	\$19.00
- 退款与坏账	-\$0.57
- MoR 费用（Paddle，实效 9.13%）	-\$1.68
- LLM 推理成本	\$0.00 （C12 为纯规则分析，零推理）
月度贡献	\$16.75 （88.1%）
客户生命周期（1 ÷ 7% 月流失）	14.3 个月
LTV	\$239

贡献毛利率 88.1% 高于 SaaS 的 75% 健康线，原因是 C12 不调用 LLM。这正是第 4 章硬过滤器第 6 条筛选的结果，不是巧合。

7.2 两个盈亏平衡点，相差 44 倍

口径	所需客户数	所需 MRR	所需月访客（要卡）
现金盈亏平衡（只覆盖 \$60/月基础设施）	3.6	\$68	186
真实盈亏平衡（含时间机会成本）	159	\$3,018	3,001

两者相差 44 倍。时间成本口径：87 小时/月 × \$30/小时 = \$2,600/月。

为什么必须同时报这两个数

只报第一个是自欺，只报第二个是自虐。

\$68 MRR 这个数会让人产生「很快就能盈利」的错觉——它的真实含义只是「服务器费用有着落了」。而 \$3,018 MRR 才是「这件事在经济上开始说得通」的门槛，模型给它的概率是 2.0%。

本 BP 的处理方式是两个都报、都标注口径，并把后者写进第 9 章 Gate 5 的通过标准。

7.3 一个通常被忽略的成本：时间计价的 CAC

单人项目没有广告预算，于是 CAC 常被记为 0。这是错的。把每月投入获客的小时数按 \$30/小时折算，就得到真实的 CAC。在「每月 8 小时获客、月访客 1,000」的情景下，时间计价的 CAC 会显著高于 LTV——这意味着靠手工获客换客户是亏的，必须依赖第 6 章那四条复利渠道，让边际获客工时随时间趋近于零。完整情景表见 `outputs/results.json → unit_economics.time_based_cac_scenarios`。

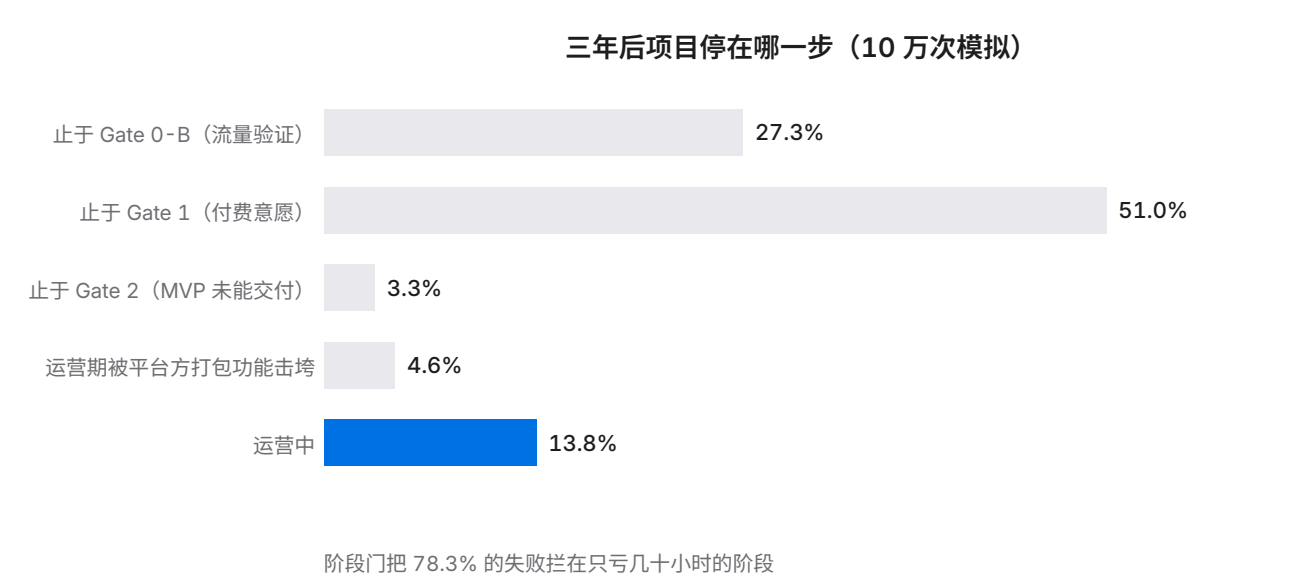
风险量化：胜率、盈亏比、Kelly 与四种年化

100,000 次三年期模拟，随机种子 20260727，任何人重跑都得到逐位相同的数字。本章与常见创业财务预测最大的不同是 **把阶段门做进了模拟**——因为门的经济意义正是截断左尾，不建模门就会系统性算错。

8.1 模型结构：三个不常见的设定

- 1. **阶段门进入模拟。** Gate 0-B 未过就停手，损失是 26 小时而不是 3,000 小时。
- 2. **时间按机会成本计价。** 全额赌注 \$94,500，其中 95.2% 是时间。
- 3. **未花掉的预算算作收回的本金。** 第 3 个月停手时剩下的 2,900 小时仍然是你的。这正是 Kelly 框架所需的口径。

8.2 三年后，项目停在哪一步

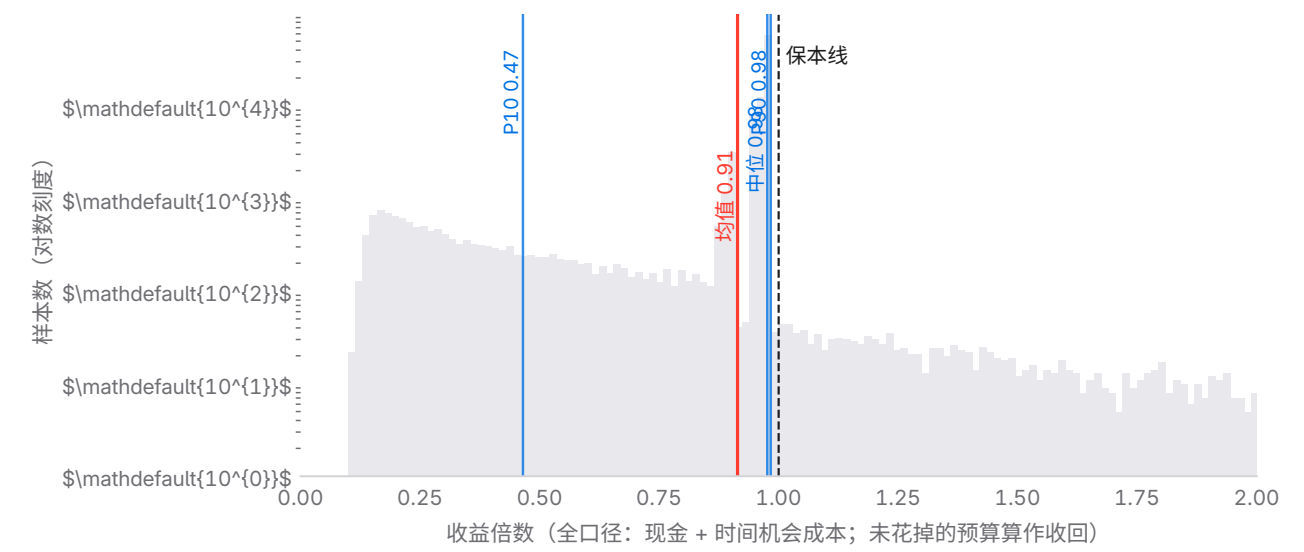


只有 18.4% 的路径能走到经营期。但请注意：78.3% 的失败发生在投入不到 100 小时的阶段——这不是坏消息，这正是阶段门在起作用。

8.3 收益分布

0.465	0.976	0.983	0.914
P10	中位数	P90	均值 (≠ 中位数)

收益倍数分布：中位数贴在保本线之下，右尾太薄以致均值仍为负



纵轴为对数刻度。84% 的样本挤在 0.97 附近的一根尖峰里（早停、只亏几十小时），线性刻度下右尾会被压成看不见的贴地线。均值低于中位数，是因为右尾太薄、补不上少数几条烧光全部工时的路径。

换成更直观的口径：第 36 个月的 MRR 中位数是 **\$0**，P90 是 **\$619**。中位数为零不是模型出错，而是**超过一半的路径在 Gate 0-B 或 Gate 1 就已经停手，根本没有走到有收入的那一步——这正是阶段门的设计意图**。达到 \$1,000 MRR 的概率为 7.2%，达到真实盈亏平衡所需 MRR 的概率为 2.0%。

8.4 胜率与盈亏比：一组极易被误读的数字

指标	全口径	口径说明
胜率 $p = P(M > 1)$	1.89%	拿回来的比投进去的多
平均盈利 W	+1.553	条件于盈利路径
平均亏损 L	0.118	条件于亏损路径，取正
盈亏比 $b = W / L$	13.20	赔率
保本所需胜率 $1/(1+b)$	7.04%	实际胜率 1.89%，不达标

胜率 1.89% 不可单独引用

孤立地看，这个数字像是「98% 的概率血本无归」。那是误读。

典型亏损只有 **11.8%**（不是 100%），因为 78.3% 的路径在 Gate 0-B / Gate 1 就停手，只亏掉几十小时的学费。

真正该看的是条件于「过了 Gate 1、真正开始重投入」（占 21.75%）的那一组：胜率 8.71%，盈亏比 3.23，期望 -0.303。风险不是均匀分布在三年里的，它集中在通过 Gate 1 之后的那 240+ 小时。

8.5 Kelly：诚实披露它在这里失效

数值最大化 $E[\ln(1 + f \cdot X)]$ （不用两结果闭式解，因为本项目的结果是六档以上的连续分布），全口径得 $f^* = 0$ ——期望优势为负，Kelly 的答案是一分钱都不要下。

KELLY 为什么在单人创业上不成立（三条结构性理由）

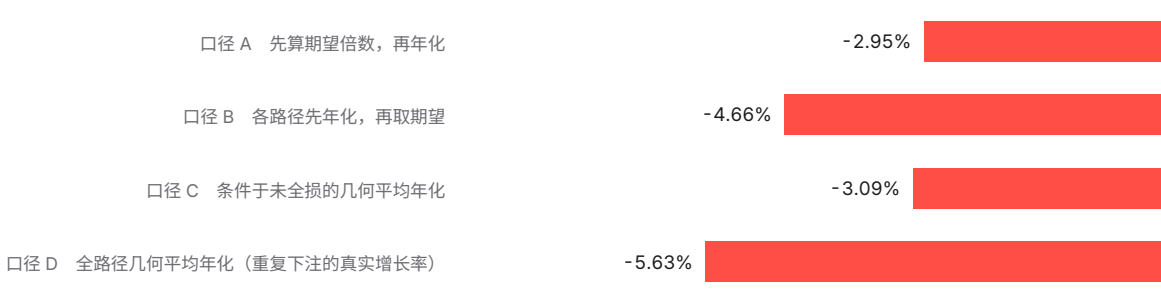
1. **Breiman(1961)** 的最优性证明全部是渐近结论 ($n \rightarrow \infty$)。Thorp 自己给的量化例子是：区分 1.0% 与 1.1% 的优势，需要**两百万次试验**才有 84% 把握。一个人一生能下的创业注是个位数，大数律完全不工作。
2. **Samuelson 1971(PNAS) / 1979(JBF)** 的正式反对：最大化 $E[\ln]$ 只有在效用函数恰好是对数时才最优，它不是一条普适定理。
3. **Kelly 假设赌注可无限分割、可重复、赔率已知**。创业三条全不满足：不能下 0.37 个产品，不能重来，赔率本身是估出来的。

因此本文件把 Kelly 的输出只作为「下注规模上限的参照」，绝不作为承诺。

8.6 四种年化口径，全部并列

同一个分布可以产出四个相差很大的「年化」。纪律：本文件任何一处「年化 XX%」必须紧跟口径名与该口径的误导风险说明，不允许只报有利的那一个。

同一个分布，四个「年化」（全口径）



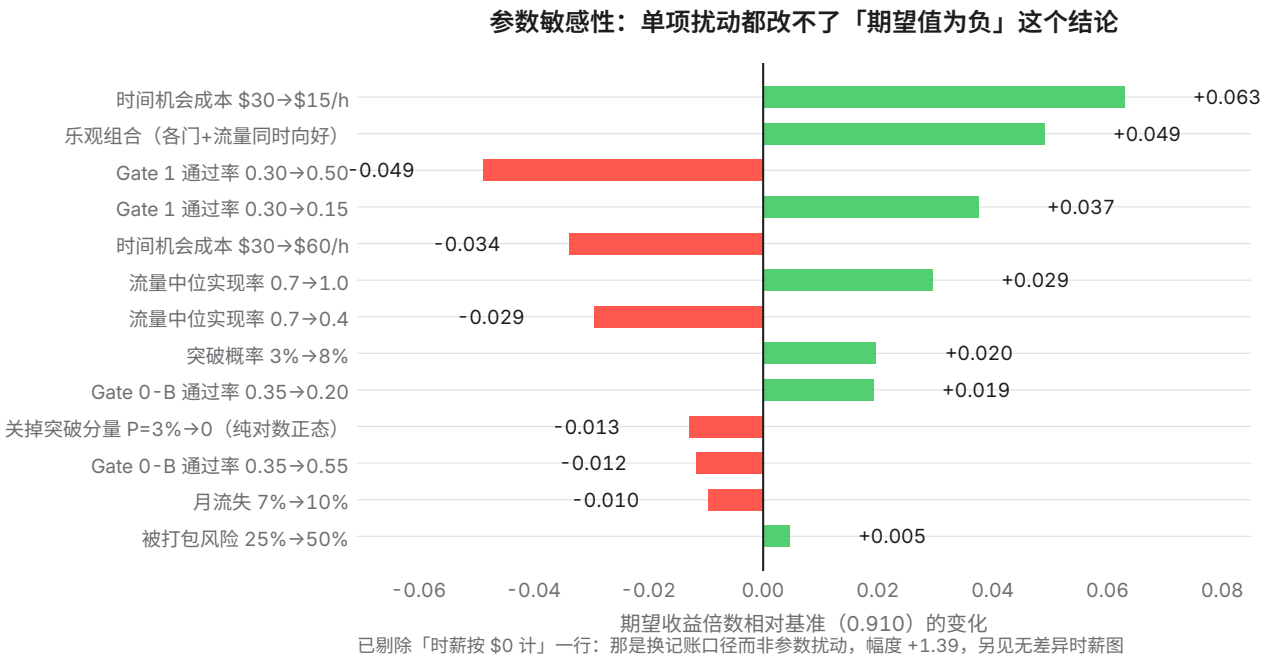
四者极差 2.7 个百分点，且全部为负。正文任何一处「年化 XX%」都必须紧跟口径名。

四者极差 2.7 个百分点，且全部为负。无风险利率参照：美国 10 年期 4.71%（FRED DGS10，2026-07-23）、中国 10 年期 1.73%（中债，2026-07-24）。

口径	值	公式	误导风险
口径 A：先算期望倍数，再年化	-2.95%	$(E[M])^{(1/T)} - 1$	最容易被误读为「预期年化收益」。它是**均值的年化**，而均值被极少数右尾路径拉动；中位路径拿不到这个数。...

口径	值	公式	误导风险
口径 B：各路径先年化，再取期望	-4.66%	$E[M^{(1/T)}] - 1$	由 Jensen 不等式，恒 $\leq$ 口径 A。它更贴近「随机抽一条路径的年化」，但把全损路径的 -100% 也平均了进来，会低估「做成时」的量级。...
口径 C：条件于未全损的几何平均年化	-3.09%	$\exp(E[\ln M \mid M > 0.25])^{(1/T)} - 1$	**隐藏了 5.0% 的全损概率。**这是创业故事里最常被单独引用的数字，也是最危险的一个。...
口径 D：全路径几何平均年化（重复下注的真实增长率）	-5.63%	$\exp(E[\ln M])^{(1/T)} - 1$	这一口径本身不误导，但**只在「能重复下很多次同样的注」时才有意义**。单人创业一生下注个位数次，此数是理论参照而非可实现收益。...

8.7 敏感性：什么能翻转结论，什么不能



没有任何单项参数扰动能把期望值扳回正数。把 Gate 0-B 通过率从 0.35 提到 0.55、把流量实现率提到 100%、把流失率降到 5%——都不够。唯一能翻转结论的是记账口径本身，即时间机会成本。

一个反直觉但重要的结果

敏感性表中的「乐观组合」（各门通过率与流量同时向好）：胜率从 1.70% 升到 7.49%，但期望值几乎没有改善。

原因是：门更容易过 → 更多路径走到底 → 更多路径烧掉全部 3,000 小时。在现有单位经济学下，「顺利通过各道门并继续投入」这件事本身就在毁灭价值。这是模型给出的最尖锐的一句话，它直接指向第 9 章：门不是用来提高胜率的，是用来在注定失败的路径上少亏钱的。

8.8 收敛性

收敛性检验必须针对**噪声最大**的统计量，而不是最稳的那个。本分布的中位数落在「止于 Gate 1」这个确定性质量点上，跨种子标准差恒为 0——好看但无信息。下表用均值与 P99.9：

模拟次数	均值	跨 8 个种子相对标准差	P99.9	P99.9 相对标准差
1,000	0.9141	1.72%	5.506	50.95%
10,000	0.9123	0.98%	5.809	19.32%
100,000	0.9113	0.29%	5.923	5.67%

P99.9 的相对标准差从 n=1,000 时的 51% 降到 n=100,000 时的 5.7%。这就是必须跑 10 万次而不是 1 万次的定量理由——右尾决定期望值，而右尾收敛最慢。

阶段目标与止损门

这一章是写给半年后的你的。那时你已经忘了今天的推理过程，只会记得自己很努力。它的唯一作用，是在你**最不想停**的那一刻，用一条今天冷静时写下的客观标准把你拦住。

9.1 门到底值多少钱

把每道门的通过概率强行设为 1.0（等于拆掉这道门）重跑模拟，期望值的变化就是这道门的价格。

每道门省下的期望损失



Gate 1（付费意愿）一门抵其余各门总和的 9 倍：它用 26 小时挡住了 240 小时的无效开发

整套门机制值 \$24,256，是现金预算 \$4,500 的 5.4 倍。在这个项目里，纪律比资本贵。

门	有门期望值	拆门期望值	这道门值	有门胜率	拆门胜率
Gate 0-B 流量验证	-\$8,690	-\$9,376	\$685	1.86%	2.55%
Gate 1 付费意愿	-\$8,690	-\$22,486	\$13,796	1.86%	6.03%
Gate 2 MVP 交付	-\$8,690	-\$9,456	\$766	1.86%	2.22%

注意最后两列：拆掉门之后胜率反而上升，期望值却大幅恶化。任何用「胜率」单指标评价止损机制的做法都会得出相反结论。

GATE 1 一道门就值 \$13,796

是其余各门总和的 9 倍。原因很朴素：它是**唯一一道在投入 240 小时开发之前、用 26 小时验证「到底有没有人肯掏钱」的关卡**。它拦掉的是最贵的那段浪费。

这也回答了第 4 章留下的问题——C12 的付费意愿证据最弱怎么办？答案不是「再多找些证据说服自己」，而是「设一道最贵的门，用 26 小时把它变成事实」。

9.2 完整台账

工时与现金双轨分别计量，累计额为封顶值（不是预期值）

门	名称	时点	本门工时	累计工时	累计现金
0-A	收款通道	第 1-2 周（与 0-B 并行）	4 h	4 h	\$512
0-B	流量验证（本项目的生死线）	第 1-3 周	22 h × 3	70 h	\$524
1	付费意愿	第 3-5 周	26 h	96 h	\$524
2	MVP 交付	第 6-17 周（12 周 × 20 小时）	240 h	336 h	\$554
3	首批留存	第 6 个月	83 h	419 h	\$614
4	复利渠道成立	第 12 个月	500 h	919 h	\$974
5	稳态可持续	第 24 个月	1000 h	1,919 h	\$1,694
—	收获期	第 25-36 月	1,000 h	2,919 h	\$2,414

预算余量：工时 3,000 - 2,919 = 81 小时；现金 \$4,500 - \$2,414 = \$2,086。

9.3 逐门的通过标准与未过时的动作

Gate 0-A · 收款通道（第 1-2 周（与 0-B 并行），4 小时）

通过标准

- A1 中国大陆自然人完成 Paddle 卖家 KYC，收到 approved 通知
- A2 境内银行账户在 Transfer Preferences 中显示 verified
- A3 拿到 Paddle 要求的材料清单（网站、条款、隐私、定价页）

通过 → 进入 Gate 1；把 MoR 实际费率回填 assumptions.py 核对

未过 → 按成本升序走三级回退：个体工商户 → 香港公司 → 美国 LLC。三级全不可行则终止，并如实写出「本商业模式无可执行形态」

不致命：有已定价的回退路径，最高约 \$500 + 年费

Gate 0-B · 流量验证（本项目的生死线）（第 1-3 周，22 小时）

通过标准

- B1 目标关键词族月搜索量合计 $\geq 1,000$ ，且 $KD \leq 20$ 的词 ≥ 5 个
- B2 近 12 个月 ≥ 10 个相关讨论串，其中 ≥ 3 个得分 > 50
- B3 免费最小工具上线 14 天内 ≥ 300 真实独立访客 且 ≥ 30 次实际使用
- B4 能写出至少一条具体复利机制，且 B3 期间观察到 ≥ 1 次第三方自发引用

通过 → 进入 Gate 1

未过 → B3 未过 → **本候选赛道作废**，回到机会集取下一名重跑 0-B。理由：连免费都没人要，收费不可能有人要。最多换 3 个赛道；三次全败则结论为「不做」，转向替代的资金与时间配置

**未通过前累计开发工时上限为 0。这是全表最重要的一条纪律

Gate 1 · 付费意愿（第 3-5 周，26 小时）

通过标准

- W1 可识别的目标仓库 ≥ 200 个（受众规模下限）
- W2 负责任披露后 $\geq 30\%$ 回复，且 ≥ 3 人主动问「有没有持续监控的版本」
- W3 价格锚定候补名单 ≥ 25 人留资，其中 ≥ 10 人选了付费档
- W4 ** ≥ 3 人真实预付 \$99**（唯一的 L3 级证据）

通过 → 进入 Gate 2，开始写第一行产品代码

未过 → W4 未过 → 赛道作废，回机会集。**不允许以「再打磨一下文案」为由重试**——预付款是二元信号，反复试探会滑向骚扰，违反 docs/WTP_VALIDATION.md §3 的道德底线

这是全流程唯一能把「口头感兴趣」变成「掏钱」的一关，也是筛掉最多路径的一关

Gate 2 · MVP 交付（第 6-17 周（12 周 $\times$ 20 小时），240 小时）

通过标准

- 自助注册 → 接入 → 出首份报告的全链路无人工介入，端到端跑通
- Paddle 订阅、开票、退款、取消四条路径全部自助可用
- 前 3 名预付客户全部完成接入并收到第一份有效报告

通过 → 进入 Gate 3，转入运营与获客

未过 → 12 周末交付 → **不加时**，砍功能到能交付为止；若砍到无价值仍不能交付，说明范围判断错误，回 Gate 1 重定范围

纯规则引擎、零推理成本，工程风险是全流程最低的一环

Gate 3 · 首批留存（第 6 个月，83 小时）

通过标准

- 付费客户 ≥ 10 个
- 月流失率 $\leq 10\%$ （连续 2 个月观测）
- 自然月访客 ≥ 300 且其中非脉冲来源占比 $\geq 50\%$

通过 → 进入 Gate 4

未过 → 客户数不达标 → 把全部工时转投获客，产品功能冻结 8 周；流失率不达标 → 停止获客，先修留存（漏水的桶不值得多倒水）

****先诊断是「桶漏」还是「水少」，两者的处置动作正好相反****

Gate 4 · 复利渠道成立 （第 12 个月，500 小时）

通过标准

- 月访客 ≥ 360 ，且脉冲渠道贡献占比 $\leq 30\%$
- $MRR \geq \$400$
- 存在至少 2 条可验证的复利机制（第三方 README 引用数、被索引的程序化页面数，二者均需月度环比为正）

通过 → 进入 Gate 5

未过 → ****这是最容易自欺的一关。若流量仍靠脉冲维持，则 docs/ACQUISITION.md 的核心假设已被证伪，必须把稳态 MRR 天花板按纯脉冲重算——大概率转负，届时应止损退出**

Gate 5 · 稳态可持续 （第 24 个月，1000 小时）

通过标准

- $MRR \geq \$1,000$ （对应约 53 个客户、月访客 ≥ 995 ）
- 月净利为正（扣除 MoR 费率、退款与基础设施）
- 月均投入工时 ≤ 87 小时（未靠透支时间维持）

通过 → 进入收获期：要么持有现金流，要么按 $2-4 \times ARR$ 寻求转让

未过 → ****触发结局判断。若 24 个月、约 1,900 小时仍换不来 \$1,000 MRR，则实现时薪已远低于 model/kelly.py 算出的无差异时薪（约 \$11.8/h），继续投入不再由数据支持，应转为维护模式或按 $2-4 \times ARR$ 出售**

模型给出的这一关通过概率仅约 7%。****写下这个数，是为了半年后不自欺****

9.4 双轨止损线：为什么不能只盯现金

	现金轨	工时轨
预算	\$4,500	3,000 小时
按 \$30/h 计值	\$4,500	\$90,000
占全额赌注	4.8%	95.2%
有无自动提醒	有（银行与信用卡账单）	无

	现金轨	工时轨
失控方式	几乎不可能	在毫无感觉的情况下被烧穿

只设现金线等于不设防。这是本项目最现实的失控方式，也是绝大多数独立开发项目实际的死法：钱没花多少，三年过去了。

工时记账规程（唯一需要人工的动作，每周 5 分钟）

- 每周日记录本周实际投入工时，累加到一个纯文本台账
- 与 9.2 节的「累计工时」列对照
- 超出当前所处门的累计上限即为触线，立即执行该门的「未过」动作，不得以「快好了」为由顺延

触线后的强制动作

- 执行该门定义的「未过」动作，不允许当场修改标准
- 若确信标准本身定错了，须先书面写出「错在哪、当初为什么这么定、新标准为何更客观」，再修改——且修改只对下一门生效，不追溯当前这一门

无人化运营：零员工怎么才算真的成立

「全 AI 公司」不是一句口号，它是一条硬约束：凡是需要人在场才能完成的环节，在本项目里都等于不存在。本章逐环节检查这条约束是否真的成立，并诚实标出唯一一个做不到的地方。

10.1 全链路的无人化检查

环节	如何做到无人化	残余人工
获客	复利渠道自行运转：GitHub Action 的安装即曝光、程序化 SEO 页面自动生成、awesome-list 被动引用	披露飞轮需人工审读（可批量，约 4 小时/月）
注册与开通	GitHub OAuth 一键授权 → 自动创建工作区 → 自动首扫，无审批环节	无
计费	Paddle 作为 MoR：订阅、发票、全球增值税代缴、退款、取消全部自助	无
交付	定时任务扫描 + 变更触发；报告自动生成并推送	无
客服	文档 + 报告内嵌解释 + 自动回复。 刻意不提供人工客服，并在定价页明示	无
监控告警	Cloudflare Workers + 健康检查 + 失败自动重试与降级	故障时需人工介入（不可避免）
止损纪律	无法软件化	每周 5 分钟工时记账

唯一一个无法自动化的环节，必须点名

第 9 章的工时记账与止损判定，无法软件化。因为它要记录和约束的是你自己的行为，而不是系统的行为。

这不是可以糊弄过去的例外。如果连每周 5 分钟的记账都做不到，那么本 BP 的全部止损设计都不成立——**而止损设计价值 \$24,256，是整个方案里最值钱的部分。**

处置建议：把台账放进 git 仓库，每次更新产生一次 commit。这样「我这周投入了多少」就变成了一条有时间戳、不可事后篡改的记录。

10.2 为什么「不提供人工客服」是可以的

这不是偷工减料，而是与定价一致的产品设计：在 \$19/月这个价位上，任何人工介入都会立刻吃掉全部贡献毛利（单客户月度贡献仅 \$16.75——一次 30 分钟的客服对话就亏了）。

诚实的做法是在定价页明示「本产品不提供人工客服」，让客户在付款前就知道自己买的是什么。把做不到的事说成做得到，才是真正的不诚信。

10.3 技术栈与成本

扫描引擎	纯规则（YAML / AST 解析），零 LLM 调用
托管	Cloudflare Workers（\$5/月）+ Postgres（\$25/月）
前端与文档	静态生成 + Vercel（\$20/月）
支付	Paddle（MoR，实效率率 9.13%）
基础设施合计	\$60/月（标准档），极简档 \$10/月

在每月几千次调用的量级，成本完全由固定订阅费主导，边际成本近似为零。这是 C12 相对于「每次操作跑 LLM」型产品的结构性优势。

合法合规与能力边界

本章的重点不是列举我们做了什么，而是明确写出哪些问题我不给答案。在超出能力边界的地方硬给结论，比不给结论危险得多。

11.1 三个必须交给持牌专业人士的问题

以下三项本文件不给答案

1. 中国税务居民取得的境外 SaaS 订阅收入在中国的纳税义务认定（经营所得 / 综合所得 / 受控外国企业规则）
2. 若采用美国 LLC，Form 5472 / Form 1120 申报义务与 ECI（有效关联所得）判定 —— **Form 5472 漏报罚款起点 \$25,000**
3. MoR 平台打款到境内的性质认定（服务贸易收入 vs 其他），及对应增值税与所得税处理

必须咨询持牌税务师。本文件在这三处的任何表述都仅为背景信息，不构成建议。

11.2 可以引用的官方原文（仅作参考）

- 《经常项目外汇业务指引（2020 年版）》（汇发〔2020〕14 号）第五十四条：个人结汇实行年度便利化额度管理，额度为每人每年等值 5 万美元。第五十六条：超过便利化额度的经常项目结汇，凭有效身份证件 + 有交易额的资金来源材料办理。第六十二条：个人不得以分拆等方式规避便利化额度管理。
- 国家外汇管理局厦门市分局澄清：「等值 5 万美元是年度便利化额度，不是限额」，真实合法的经常项目结汇无金额限制。
- 《关于支持贸易新业态发展的通知》（汇发〔2020〕11 号）：从事跨境电子商务的境内个人，提供交易额证明的，不占用年度便利化额度。存疑：SaaS 订阅是否被认定为该项下服务贸易，取决于经办银行认定，各行口径不一，开户前必须确认。

11.3 明确不采纳的做法

做法

为什么不做

用住宅代理 + 境外实体伪装成在当地运营

可能违反支付服务商的服务协议，后果是账户冻结与资金扣留。合规的做法是真实地在受支持辖区设立实体并实际运营，而不是伪装成在那里

分拆结汇、借用他人额度、虚构交易背景

违反汇发〔2020〕14 号第六十二条。宁可多付费率、多缴税，不碰这条线

做法	为什么不做
检索到的「从大陆实操开通 Stripe」类指南	多为营销内容，部分做法可能违反服务协议。 一律不予采纳、不予背书

11.4 产品本身的伦理底线

本项目的核心动作之一是「在公开仓库中发现安全漏洞」。这件事离骚扰只有一步之遥，因此定死三条：

- **先修复，后营销。**每次披露必须附上可直接使用的修复补丁，而不是只报告问题然后推销产品。
- **不公开未修复的漏洞。**给足合理的修复窗口，绝不用「公开曝光」施压。
- **不反复试探同一批人。**Gate 1 的预付款测试**明确禁止以「再打磨一下文案」为由重试**——预付款是二元信号，反复试探会从「验证」滑向「骚扰」。这条限制的优先级高于商业利益。

一个检验方案是否向善的简单标准

如果这门生意失败了，被我扫描和披露过的那些仓库，是不是仍然变得更安全了？

答案是肯定的。免费的扫描工具、公开的修复补丁、被修好的配置，这些不会因为我没挣到钱而消失。一个即使失败也给世界留下净收益的方案，才配称为「向善」。这不是修辞——它同时也是本方案在道德上敢于执行的理由。

红队自检：这个项目最可能怎么死

这一章不放在附录，因为它是本文件最有用的部分。一份不敢写「我可能错在哪」的计划书，等于没有做过检验。

12.1 逆否检验：什么证据会证明我错了

我现在相信的	什么证据会推翻它	何时能知道
agent CI 配置安全是个真问题，有人愿意付费	Gate 1 的 W4：3 个人预付 \$99。拿不到就是错了，没有第二种解释	第 5 周
免费工具能带来自然流量	Gate 0-B 的 B3：14 天 300 UV + 30 次使用。拿不到说明这个话题没有自然分发力	第 3 周
复利渠道能在 36 个月内累积到 2,500 UV/月	第 12 月脉冲渠道贡献占比仍 > 30%，说明所谓「复利」其实是一次次手工推广	第 12 月
纯规则引擎不会被 LLM 方案碾压	出现一个用 LLM 做 agent 配置语义审计、且成本可控的竞品	持续观察
GitHub 不会自己做这件事	GitHub Advanced Security 或 Actions 内置 agent 工作流安全检查	持续观察（模型给 4.6% 概率）
我的时间机会成本低于 \$12.3/小时	这一条无法被外部证据推翻，只能由你自己诚实回答。它也是最可能出错的一条	现在

12.2 本方案已知的六个弱点（不辩解，只列出）

- 第 6 章（获客）的证据强度最弱。四条复利渠道里三条是 D 级本人假设，没有公开数据支撑。这是全文最软的一环，也正因如此把 Gate 0-B 设成了一票否决。
- 门的通过概率全部是 SELF 级主观估计。Gate 0-B 取 0.35、Gate 1 取 0.30，只有类比、没有外部数据。已做 ±0.15 敏感性分析（方向不变，幅度变化显著），但读者应把它们当作「我的先验」而非「事实」。
- 终值假设（2-4 × ARR、50% 流动性概率）无可靠公开数据。微型 SaaS 的真实成交倍数与成交概率都缺乏可查证样本。
- 第 9 章第 3-5 关的标准比第 0-2 关软。它们依赖运营数据，存在被「口径解释」软化的空间。处置：口径定义须在进入 Gate 3 之前一次性写死并存档。
- 模型没有建模「竞品降价」与「客户被整合方吸走」。在一个已进入整合期的赛道里，这是真实存在但难以量化的风险。

6. **本 BP 的作者和执行者是同一个人。**门是我自己定的，也是我自己判定的。没有第三方能阻止我在第 12 个月说服自己「再给三个月」。唯一可用的对冲是：**把标准写死在版本控制里，让每一次放松标准都留下 diff。**这不完美，但比什么都不做强。

12.3 如果非要给一个执行建议

不要一次决定「做还是不做」，只决定「要不要花 96 小时」

本 BP 的全部结构都指向这一点。完整投入的期望值是负的，但前三道门只要 96 小时、\$524 现金，而它们能把这个项目最大的两个未知数（拿不拿得到流量、有没有人肯付钱）变成事实。

96 小时 $\approx$ 5 周的业余时间。按 \$30/小时计，成本 \$2,880。用 \$2,880 买断两个决定成败的未知数，这笔交易本身是划算的——即便最终结论是「不做」，你也用最低成本买到了一个确定的答案，而不是在十年后仍然想着「当年那个想法要是做了会怎样」。

决策建议：批准 Gate 0 与 Gate 1 的 96 小时预算。Gate 2 及以后的 2,823 小时，等前三道门的真实数据出来之后再议——届时用同一个模型重算，不要用感觉。

12.4 交付前自检清单

检查项	状态	证据
每个环节都能由软件/AI 自动完成，无人工依赖	部分通过	唯一例外：每周 5 分钟工时记账，已在 10.1 点名
每个关键数字都有可查证出处，或附可复现的 Python 计算	通过	模型数字经 <code>key_numbers</code> 白名单从 <code>results.json</code> 取，取不到即构建失败；外部事实数字就近标注出处，且被 <code>audit_numbers.py</code> 钉成基线，新增即报错（见附录 C.3）
不确定与推测已明确标注，没有任何编造内容	通过	五级证据分级；C 级内容农场数据已隔离；4 处无公开数据项已标注类比推算
方案写明了执行主体、前置条件、所需资源与分步骤	通过	第 9 章逐门给出时点、工时、标准与处置动作
已做合法性与风险性评估，符合公序良俗	通过	第 11 章，含三项明确的能力边界声明
阶段目标可分解，每阶段有客观可检验的验收标准	通过	7 道门，全部为二元可判定标准
允许并保留得出「不建议做」的结论	通过	第 1 章给出的正是一个有条件的否定结论

附录 A

方法论：被禁用的公式与不适用的指标

这些不是从教科书上抄来的告诫，而是在本项目自己的数据上跑出来的反驳。列出它们，是为了防止自己或后来的读者图省事又把它们捡回来。

A.1 禁用 $g \approx \mu - \sigma^2/2$ 波动率拖累近似式

在创业级波动下，这个近似式连符号都会算错。用本项目的两组数据实测：

口径	精确值 $E[\ln M]$	近似值 $M - \Sigma^2/2$	误差	符号是否反了
全口径	-0.1739	-0.3094	-0.1355	否
现金口径	+0.1892	-99.9490	-100.1382	是

现金口径下近似式给出 -99.9，精确值 +0.19。近似式只在小波动下成立，而本项目的算术标准差远超其适用范围。一律用精确式与蒙特卡洛交叉验证。

A.2 禁用「半 Kelly 保留 75% 增长率」的 $c(2-c)$ 近似

这个说法流传极广，其严格来源是 Thorp 2006 eq.(7.7) 的连续/对数正态近似。用本项目的离散分布实测（现金口径，因全口径 $f^* = 0$ 无从谈起）：

分数 C	$F = C \cdot F^*$	实测保留比例	$C(2-C)$ 近似	差
0.25	0.2888	60.3%	43.8%	+16.5 pp
0.5	0.5775	81.6%	75.0%	+6.6 pp
0.75	0.8663	93.4%	93.8%	-0.3 pp
1.0	1.1550	100.0%	100.0%	+0.0 pp
1.5	1.7326	下注过量，存在被打光的路径	75.0%	—
2.0	2.3101	下注过量，存在被打光的路径	0.0%	—

实测半 Kelly 保留 81.6%，而非流传的 75.0%。更值得注意的是 1.5 倍与 2 倍 Kelly：近似式给出 75% 与 0%，而实测结果是存在会被彻底打光的路径——近似式在这里不只是不准，是给错了性质。

A.3 不把夏普 / 索提诺 / Omega 作为结论性指标

指标	全口径实测值	为什么不能用
夏普比率	-0.350	以「收益对称、波动可作风险代理」为前提

指标	全口径实测值	为什么不能用
索提诺比率	-0.675	改善了下行度量，但仍假设分布可用二阶矩描述
Omega	0.103	对阈值极敏感，本分布下不具可比性
偏度	67.8	正态分布为 0。这就是上述三者失效的原因
超额峰度	8,176	正态分布为 0

在偏度 68、超额峰度 8,176 的分布上，标准差主要由**右尾的好结果**贡献，于是「波动越大 = 越危险」的解读方向是反的。**把这组数字放进正文只会让读者得到与事实相反的印象**，故仅在此作为反例出现。

附录 B

假设总表与出处

全部数值假设集中在 `model/assumptions.py`，其他任何文件禁止硬编码数字。每个常量注明单位、证据等级与出处。

证据分级：A 一手权威来源 B 可靠二手 C 存疑（已隔离，不作建模输入） D 无公开数据、类比推算 SELF 本人主观估计

常量	取值	单位	等级	说明与出处
HOURS_PER_WEEK	20	小时/周	SELF	委托方给定的可投入时间上限
WEEKS_PER_YEAR	50	周/年	SELF	扣除约 2 周完全无产出的时间（春节、病假等）
HOURS_PER_YEAR	1000	小时/年	SELF	= HOURS_PER_WEEK × WEEKS_PER_YEAR = 1,000 小时
CASH_CAP_USD	4000.0	美元	SELF	现金投入上限，占可投资净资产 <5%，破产可承受且不可追加
INVESTABLE_NET_ASSETS_USD	80000.0	美元	SELF	由「\$4,000 占可投资净资产 <5%」反推的下限；Kelly 的 bankroll 口径。真实值只有委托方知道，此处取满足约束的最小值，属保守处理
ENTITY_SETUP_RESERVE_USD	500.0	美元	SELF	Gate 0-A 回退时的主体设立预留（个体工商户 ~\$0 / 香港公司 ~\$1,500 / 美国 LLC ~\$500）。取美国 LLC 档，因其为最可能被采用的回退路径
HOURLY_OPPORTUNITY_COST_USD	30.0	美元/小时	SELF	个人时间的机会成本。**这是本模型中最重要也最主观的一个数**：按此计价，一年 1,000 小时 = \$30,000，是现金投入 \$4,000 的 7.5 倍。**真正的赌注是时间而非金钱**，必须做敏感性分析
CM_OPTIN_VISITOR_TO_SIGNUP	0.045	比例	A	free trial（不要信用卡）访客→注册；ChartMogul 原文 45 注册/千访客
CM_OPTIN_SIGNUP_TO_PAID	0.089	比例	A	free trial（不要信用卡）注册→付费（6 个月内）；原文 3.6 付费/千访客 ÷ 45 注册
CM_CARD_VISITOR_TO_SIGNUP	0.035	比例	A	free trial（**要**信用卡）访客→注册；注册量比不要卡低约 22%

常量	取值	单位	等级	说明与出处
CM_CARD_SIGNUP_TO_PAID	0.314	比例	A	free trial (**要**信用卡) 注册→付费；原文 10.5 付费/千访客 ÷ 35 注册
SOLO_NO_TOUCH_DISCOUNT	0.33707865168539325	倍数	D	单人零人工触点的折扣系数 ≈ 0.337。推导：BENCHMARKS.md 建议把 ChartMogul 的 8.9% 下调至 3.0% 建模，理由是该样本典型受访者已在 \$1M-\$10M ARR 且有市场团队，而 ChartMogul 同
MONTHLY_LOGO_CHURN	0.07	比例/月	B	客单价 \$10-50/月自助订阅的月度客户流失。取 Baremetrics 分档表 \$25-50 档的 7.3% 与 <\$10 档的 6.2% 之间。单人无任何人工挽留动作，不宜取更低值
NRR_ABOVE_100_PROBABILITY	0.027	比例	A	ARPA <\$10/月的公司中净收入留存 >100% 的比例仅 2.7%。**据此模型中一律不假设扩张收入**
ARPU_USD	19.0	美元/月	SELF	客单价。下限由 MoR 费率结构决定：\$9 档 MoR 有效费率高达 12.1-12.6%，\$19 档降至 7.6-9.6%。上限由竞品价格带 (\$12-\$30) 与 Copilot \$10 天花板约束
MOR_RATE_PCT	0.05	比例	A	Paddle 基础费率 5% (全包，含国际卡、换汇、订阅附加与全球税务代缴)
MOR_FEE_FIXED_USD	0.5	美元/笔	A	Paddle 每笔固定费
MOR_FX_MARGIN_PCT	0.015	比例	A	Paddle 在打款币种与余额币种不同时收取的汇兑价差，最高 1.5%。选择 CNY 打款到境内银行时适用
MOR_PAYOUT_THRESHOLD_USD	100.0	美元	A	Paddle 最低打款门槛，未达门槛顺延次月。含义：现金回笼最长延迟约 60 天
REFUND_RATE	0.03	比例	D	退款与坏账率。无本赛道公开数据；按 SaaS 常见 2-5% 取中值
INFRA_MONTHLY_USD	60.0	美元/月	A	标准档：Vercel Pro \$20 + Supabase Pro \$25 + Cloudflare Workers \$5 + 域名与杂项 \$10。在每月几千次调用量级，成本完全由固定订阅费主导

常量	取值	单位	等级	说明与出处
INFRA_MINIMAL_MONTHLY_USD	10.0	美元/月	A	极简档：Cloudflare Workers \$5 + Neon 按量约 \$4 + 域名分摊 \$1
LLM_COST_PER_OP_USD	0.0	美元/次	A	**头号候选 C12 为纯 YAML/AST 规则分析，零推理成本。** 此常量存在的意义是：当敏感性分析切换到含推理的候选时，用 Ellipsis 公布的生产均值 \$0.12/次替换（见 LLM_COST_AGENTIC_USD）
LLM_COST_AGENTIC_USD	0.12	美元/次	A	agentic 代码审查的真实生产均值（已做分层路由+增量处理+缓存三件套后）。**更正记录：先前误用 \$0.74，那是 Ellipsis 的售价（token 透传 \$0.37 + 100% 平台费 \$0.37），不是成本。** 未优化的朴
LLM_COST_SINGLE_PASS_USD	0.0714	美元/次	D	单次推理式审查（Claude Sonnet 5 引导价，10 文件 PR，60% 缓存命中）的自下而上推算。与 Ellipsis 生产均值 \$0.12 相差 1.7 倍，属同一量级，互相印证
SONNET5_PRICE_HIKE_DATE	2026-09-01	日期	A	Claude Sonnet 5 由 \$2/\$10 涨至 \$3/\$15（+50%）。**任何跨越 9 月的推理成本测算不得使用现价**
PARTTIME_PENALTY	2.2	倍数	B	兼职惩罚系数：全职创始人的公司增速是兼职创始人的 2.2 倍（MicroConf 2024, n=469, p.45）。推论：所有里程碑耗时乘以 2.0–2.5
MEDIAN_MONTHS_TO_1K_MRR_FULLTIME	15.0	月	D	全职达到 \$1,000 MRR 的中位耗时，取流传区间 12–18 个月的中值。**原始来源 RockingWeb 2025 为 C 级（无公开数据集与抽样框），故此处降级为 D 级类比推算，仅用于粗略排期，不得作为概率输入**
PROJECT_ALIVE_12M	0.9	比例	B	项目 12 个月后才在线运行的比例。Show HN 10,000 条提交的年均死亡率约 9%。**局限：HTTP 200 只证明域名还在，不证明还有收入**

常量	取值	单位	等级	说明与出处
PMF_FAILURE_SHARE	0.43	比例	A	产品-市场不匹配在失败原因中占 43% (CB Insights, n=431)。对纯自有资金项目, 第一大终局原因「资金耗尽 70%」基本不适用, 真实风险几乎全部集中在 PMF 与时间机会成本上
SEO_TOP10_PROBABILITY_12M	0.0174	比例	A	新页面 12 个月内进入 Google 前十的概率 (100 万随机 URL 追踪)。英文非空内容筛选后为 6.11%; 高搜索量词仅 0.3%。**据此第一年的 SEO 流量一律按 0 计**
HN_FRONTPAGE_UV	15000	独立访客/次	B	一次 Hacker News 头版的 24 小时流量, 取 10,000-30,000 区间下沿。 **48 小时内衰减到零, 是脉冲不是渠道**
PRODUCT_HUNT_SIGNUPS	125	注册/次	D	一次 Product Hunt 发布的 7 日注册量, 取 100-150 中值。**原始来源样本极小 (C 级), 此处降级为 D 级类比推算**
MARKETPLACE_INSTALL_TO_PAID	None	比例	D	GitHub / VS Code Marketplace 安装 → 付费转化: **无任何公开可靠数据**。模型中不使用该路径, 或用漏斗基准值替代并明示为类比
RF_US_10Y	0.0471	年化	A	美国 10 年期国债收益率
RF_CN_10Y	0.0173	年化	A	中国 10 年期国债收益率
HORIZON_YEARS	3.0	年	SELF	评估期。选 3 年的理由: 与 Show HN 存活曲线 (约 6 年后死比活更可能) 和兼职惩罚下达到 \$1K MRR 需 24-30 个月这两条相容
ANGEL_IRR_BENCHMARK	0.314	年化 IRR	A	Wiltbank & Boeker (2007) 天使投资 2.6 倍 / 3.5 年。**订正记录: 原报告写作约 27% 系计算错误, 正确值为 $2.6^{1/3.5} - 1 = 31.4\%$ **

附录 C

复现说明

C.1 一条命令

python model/run_all.py && python bp/build_html.py && python bp/build_pdf.py

随机种子固定为 20260727，100,000 次模拟。任何人在任何时间重跑，都会得到与本文件**逐位相同**的数字。

Python	3.12.10
NumPy	2.5.1
运行平台	Windows - 2025Server - 10.0.26100 - SP0
代码版本	git f543c8f
生成时间	2026-07-27T04:25:06Z
全流程耗时	25.1 秒

C.2 文件清单

文件	作用
model/assumptions.py	唯一的假设来源，含自检
model/opportunity_scoring.py	16 候选 × 12 硬过滤 × 9 维加权 + 敏感性与稳健性
model/funnel.py	自下而上漏斗，含信用卡开关
model/unit_economics.py	单客户经济性、双口径盈亏平衡、时间计价 CAC
model/acquisition.py	渠道模型与缺口分析
model/monte_carlo.py	10 万次模拟，阶段门进入模型
model/kelly.py	胜率/盈亏比/Kelly/四种年化/无差异时薪
model/gates.py	止损台账与每道门的定价
model/figures.py	SVG 矢量图表
model/run_all.py	一键复现 + 跨模型交叉校验
bp/build_html.py	本文件的生成器（数字全部取自 results.json）

文件	作用
bp/build_pdf.py	Playwright 导出 PDF 并校验
docs/GATE0.md 等	各专题的完整论证
research/sources.md	事实底稿，每条含 URL、日期与证据分级

C.3 对账保证

正文里的数字分两类，两类各有各的保证

第一类：本项目模型算出来的数字（工时、金额、概率、转化率、期望值）。本文件由 `bp/build_html.py` 从 `outputs/results.json` 渲染，这类数字一律经白名单函数取值，**取不到就抛异常、构建失败**。本次构建共引用 44 个关键数字，白名单覆盖率 100.0%。所以「正文与模型一致」是结构性保证：模型参数变了而正文没跟着变，构建会失败，而不是静默产出一份过期文件。

第二类：外部事实数字（竞品定价、他人营收、法规日期、第三方问卷比例）。这类数字是手打的，而且**本就不该来自本项目的模型**——它们的效力来自出处，因此每一处都就近标注了来源与核查日期，底稿在 `research/sources.md`。

这个区分本身也被自动守住：`tools/audit_numbers.py` 把当前 106 处外部事实数字指纹化钉成基线，此后任何新增的手打数字都会让检查失败，必须要么改为从模型取值，要么显式复核入基线并留下 diff。换句话说，**第一类数字不可能被手打偷偷替换掉**。